

Manual 06 - HIPAA Implementation and Audit

CONTROLLED PUBLICATION QA CANDIDATE

Controlled source revision: 152d9d8520d40aab269e7760c73ea096e7ea90b6 | Language: en | current-law/proposed-rule source-state controls retained.

Legal and assurance boundary: This educational manual does not determine covered-entity or business-associate status, legal sufficiency, HIPAA compliance, or whether an incident is a reportable breach. Proposed Security Rule material is readiness-only unless and until HHS issues a final rule and the controlled baseline is updated. Organization-specific legal and compliance decisions require qualified human judgment.

Implementation and audit paths

Manual 06 — HIPAA Implementation and Audit Paths

Essential

Use for smaller or less complex environments with bounded PHI/ePHI flows. Establish at minimum:

- entity/role classification and accountable owners;
- PHI/ePHI inventory and data-flow map;
- current-law applicability record;
- Security Rule risk analysis and risk-management plan;
- administrative, physical, and technical safeguard evidence;
- workforce authorization/training records;
- business-associate inventory and BAA tracking;
- incident/breach-response workflow;
- documentation and corrective-action records.

Structured

Use for multi-site, multi-system, cloud-heavy, vendor-dependent, or moderately complex healthcare environments. Add:

- formal data-flow and system-boundary review;
- risk-register linkage to corrective actions;
- periodic access/log review;
- supplier due diligence and evidence refresh;
- documented contingency, backup, restoration, and emergency-mode testing;
- structured breach-assessment records;
- compliance evidence sampling and independent review.

Enhanced

Use for large, highly regulated, high-volume, complex, or critical healthcare environments. Add:

- enterprise control ownership and second-line assurance;
- broader technical validation and continuous monitoring;
- cross-entity/supplier dependency mapping;
- scenario-based incident and breach exercises;
- enhanced data-governance and identity controls;
- formal exception/risk-acceptance governance;
- recurring internal audit and executive oversight;
- change-impact analysis for HHS rulemaking and material technology changes.

Current law versus proposed rule

Manual 06 memory graphic 1

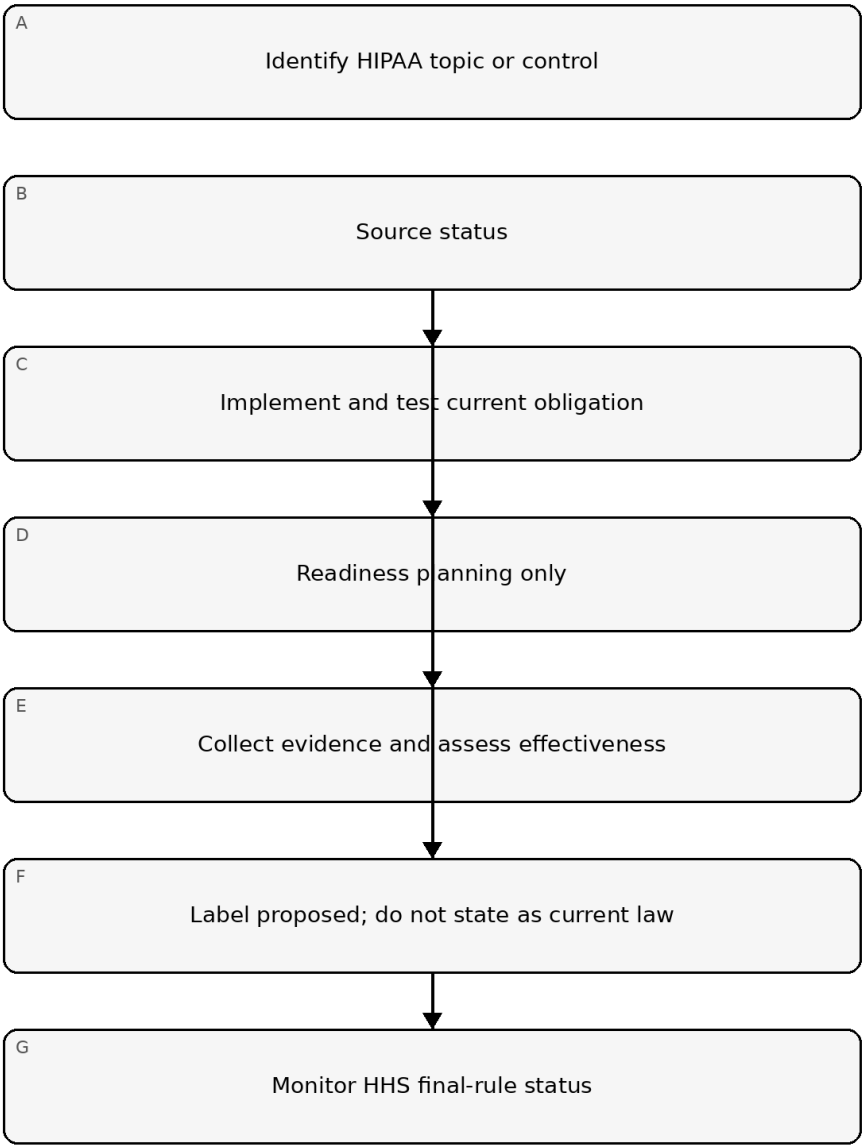


Figure 1. Implementation memory graphic

Accessible explanation: Current final rules and official guidance may drive present implementation. NPRM material is used only for readiness planning, is visibly labeled proposed, and is re-evaluated when HHS changes its status.

Implementation cycle

Manual 06 memory graphic 2

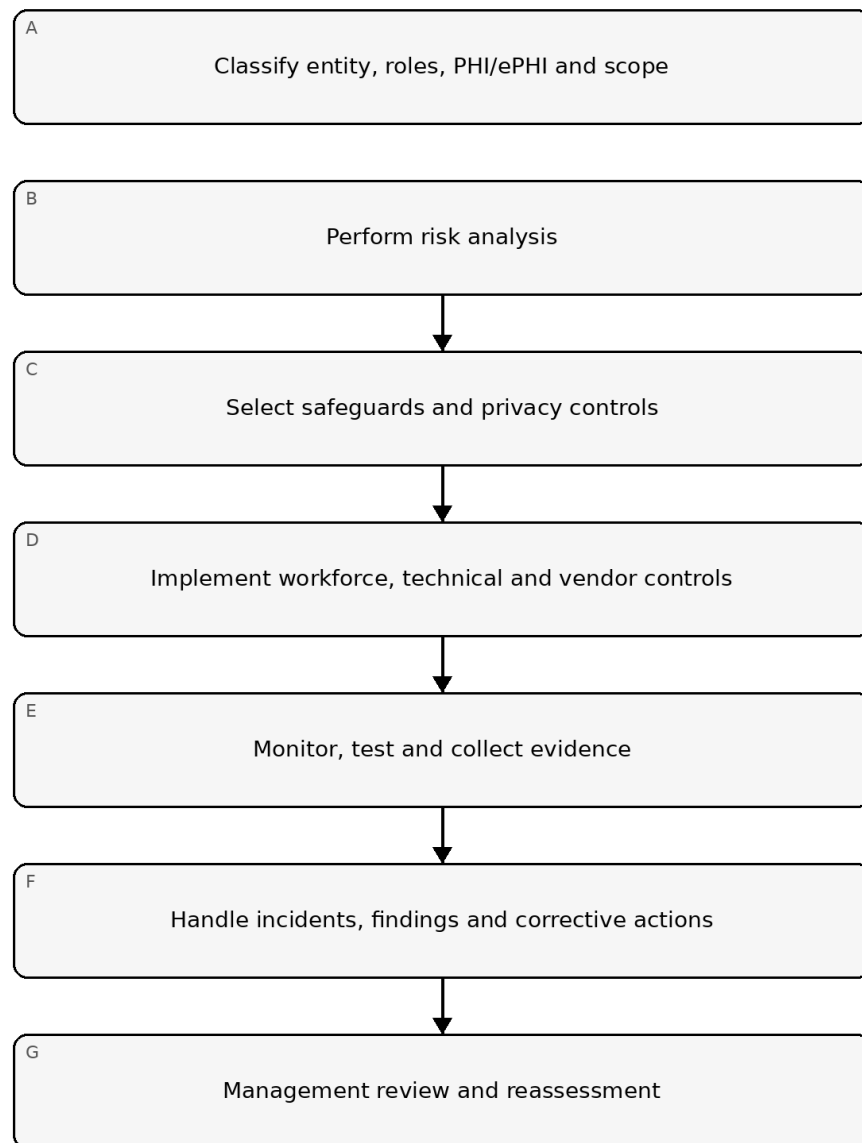


Figure 2. Implementation memory graphic

Accessible explanation: HIPAA implementation is cyclical: define scope and data, analyze risk, implement safeguards and privacy controls, collect evidence, correct deficiencies, and reassess after changes.

Evidence chain

Manual 06 memory graphic 3

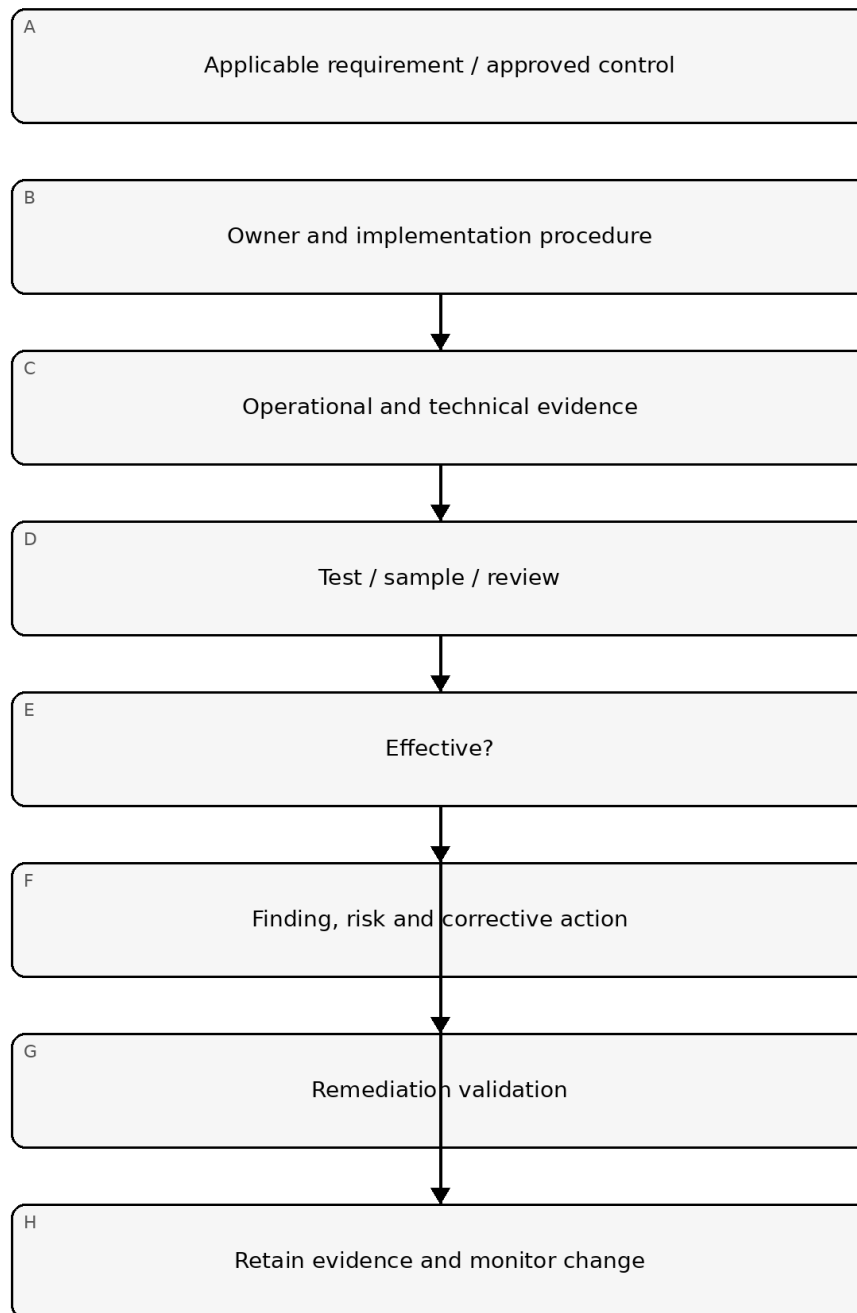


Figure 3. Implementation memory graphic

Accessible explanation: Requirements are connected to accountable owners, operating evidence, testing, findings, remediation validation, and retained evidence. A policy by itself is not proof that a safeguard is operating effectively.

Required implementation areas

The controlled chapter master will expand these areas:

1. Covered entity and business associate determination support.
2. PHI/ePHI inventory, data flows, systems, facilities, workforce, and suppliers.
3. Privacy Rule operational controls, including minimum necessary and permitted uses/disclosures.
4. Security Rule risk analysis and risk management.
5. Administrative safeguards.
6. Physical safeguards.
7. Technical safeguards.
8. Workforce access, authorization, training, sanctions, and termination/change controls.
9. Business Associate Agreements and supplier lifecycle governance.
10. Incident response and breach assessment/notification workflow.
11. Contingency planning, backup, recovery, emergency operations, and testing.
12. Documentation, retention, evidence management, audit testing, and corrective action.
13. Regulatory change monitoring, with proposed rules separated from current law.

Assurance boundary

This manual will help structure implementation and audit evidence. It will not determine legal status, legal sufficiency, reportability of a breach, or formal compliance for a specific organization. Those determinations require organization-specific facts and qualified human judgment.

Controlled 32-chapter manual

Chapter 01 — Scope, entity role, and accountability

Begin by determining which organizational units, systems, services, and relationships fall within the HIPAA implementation scope. Record the basis for covered-entity, health-plan, health-care-provider, clearinghouse, business-associate, or subcontractor treatment where applicable, and identify accountable privacy, security, legal, compliance, operations, and business owners.

The implementation record should distinguish confirmed facts from assumptions requiring legal or regulatory interpretation. Scope decisions should be dated, evidence-backed, and reassessed after material organizational, service, data-flow, acquisition, or regulatory change.

Chapter 02 — PHI and ePHI inventory

Organizations should maintain an inventory of protected health information and electronic protected health information that identifies where information is created, received, maintained, transmitted, stored, backed up, exported, or disposed of.

Records should identify systems, applications, endpoints, databases, cloud services, interfaces, removable media, paper processes where relevant, owners, custodians, data classifications, retention requirements, and external recipients. Unknown repositories and unmanaged exports should be treated as control gaps requiring investigation.

Chapter 03 — Data-flow and boundary mapping

Map how PHI and ePHI move between workforce members, applications, facilities, cloud services, vendors, business associates, patients, health plans, providers, and other authorized recipients. Include trust boundaries, authentication points, interfaces, APIs, file transfers, messaging, remote access, and backup or archival paths.

Data-flow maps support risk analysis, minimum-necessary review, access-control design, incident investigation, business-associate governance, and breach assessment. Maps should be versioned and linked to the systems and processes they represent.

Chapter 04 — Privacy governance and minimum necessary

Privacy governance should define who may use or disclose PHI, for what purpose, under what authority, and with what approval or verification. Where the minimum-necessary standard applies, processes should limit access, use, disclosure, and requests to the amount reasonably needed for the permitted purpose.

Role design, workflow approvals, reports, exports, analytics, support access, and administrative privileges should be reviewed for unnecessary exposure. Exceptions should identify rationale, authority, scope, owner, duration, and compensating controls.

Chapter 05 — Security Rule risk analysis

Risk analysis should be accurate and thorough for the organization's ePHI environment. It should identify assets, data flows, threats, vulnerabilities, existing safeguards, likelihood, potential impact, and resulting risk using a repeatable method appropriate to organizational size, complexity, capabilities, technical infrastructure, and risk context.

A risk analysis is not complete merely because a checklist was filled in or a vulnerability scan was run. Evidence should show the systems and ePHI considered, assumptions, methods, findings, limitations, responsible reviewers, and date of analysis.

Chapter 06 — Risk management and treatment

Risk management should convert identified risks into accountable treatment decisions. For each material risk, record the planned safeguard or corrective action, owner, target date, dependencies, interim controls, residual risk, approval, and evidence of completion.

High-risk items should not remain indefinitely open without escalation or documented acceptance by an authorized risk owner. Completed remediation should be validated rather than closed solely on management assertion.

Chapter 07 — Administrative safeguards

Administrative safeguards should translate HIPAA security responsibilities into operational governance. Relevant controls include assigned security responsibility, workforce authorization and supervision, information-access management, security awareness and training, security-incident procedures, contingency planning, evaluation, and business-associate arrangements where applicable.

Implementation should show who performs each control, how often it occurs, what evidence is retained, what exceptions exist, and how failures are escalated.

Chapter 08 — Fail-closed implementation gate

A HIPAA implementation or audit package should fail closed when material scope is unresolved, required current-law analysis is missing, ePHI boundaries are unknown, significant risk-analysis gaps remain, evidence cannot support claimed safeguards, or required human/legal/compliance review is incomplete.

Automated repository QA may confirm structure, source-state records, links, and publication evidence. It cannot determine legal status, control effectiveness, compliance, or breach-reporting obligations. Material changes reopen affected review gates.

Chapter 09 — Workforce authorization and access lifecycle

Workforce access should be granted according to role, job need, authorization, and minimum-necessary principles where applicable. Joiner, mover, and leaver processes should define approval, provisioning, review, modification, suspension, and termination responsibilities.

Evidence should include access requests, approvals, role definitions, periodic reviews, privileged-access records, termination timing, and exception handling. Shared or orphaned accounts should be identified and remediated.

Chapter 10 — Identity, authentication, and privileged access

Systems containing ePHI should use identity and authentication controls appropriate to risk and technology. Privileged access should be limited, separately governed, monitored, and reviewed.

Administrative and service-account use should be traceable where feasible. Credentials, tokens, keys, and secrets should be protected throughout their lifecycle, and emergency-access procedures should be controlled and auditable.

Chapter 11 — Technical access and transmission controls

Technical safeguards should control access to ePHI and protect information during transmission according to the applicable environment and risk. Implementation records should identify access-control mechanisms, unique-user identification, authentication, session behavior, remote-access controls, encryption or equivalent protections where used, and network or application transmission paths.

Control descriptions should reflect actual deployed configurations rather than policy statements alone.

Chapter 12 — Logging, monitoring, and audit controls

Organizations should define security-relevant logging and review sufficient to support accountability, detection, investigation, and evidence. Relevant records may include authentication events, privilege changes, access to sensitive data, administrative actions, security alerts, configuration changes, and system events.

Logging scope, retention, access protection, review frequency, alert ownership, escalation, and evidence preservation should be documented. Missing logs or unreviewed critical alerts should be treated as risk rather than assumed control coverage.

Chapter 13 — Endpoint, server, and infrastructure protection

Endpoints, servers, virtual infrastructure, cloud services, and other platforms that create, receive, maintain, or transmit ePHI should be managed through risk-based configuration, vulnerability, patching, malware-defense, access, backup, and monitoring practices appropriate to the environment.

Evidence should distinguish implemented safeguards from planned safeguards and record exceptions, unsupported systems, compensating controls, and remediation ownership.

Chapter 14 — Physical safeguards

Physical safeguards should address facilities, workstations, devices, media, and environmental conditions that can affect the confidentiality, integrity, or availability of ePHI. Access to sensitive locations and equipment should be limited and managed according to business and security needs.

Device and media controls should cover movement, reuse, disposal, sanitization, inventory, loss, and transfer where applicable. Physical safeguards should be coordinated with workforce, technical, and contingency controls rather than reviewed in isolation.

Chapter 15 — Backup, contingency, and availability

Contingency planning should identify critical systems and data, backup requirements, restoration methods, emergency operating needs, communications, dependencies, and testing responsibilities. Recovery objectives should reflect business and patient-care consequences where relevant.

Backups should be protected, monitored, and periodically tested for recoverability. A backup process should not be credited as effective solely because jobs report success; restoration evidence should be retained for representative tests.

Chapter 16 — Security awareness and workforce training

Workforce members should receive security and privacy training appropriate to their responsibilities, access, risk, and technology use. Training should address expected behavior, incident reporting, credential protection, phishing or social-engineering risk, handling of PHI/ePHI, remote work, and role-specific obligations where relevant.

Evidence should show assignment, completion, exceptions, overdue items, supplemental training after incidents or material changes, and accountability for persistent non-compliance.

Chapter 17 — Security incident response

HIPAA-related security events should enter a defined incident process with clear roles for detection, triage, containment, evidence preservation, technical response, privacy/compliance review, legal escalation where appropriate, recovery, and lessons learned.

Incident records should identify affected systems and information, timing, actions taken, decision owners, communications, unresolved questions, and follow-up remediation. Significant incidents should trigger reassessment of relevant risk analyses and safeguards.

Chapter 18 — Breach assessment workflow

Potential unauthorized acquisition, access, use, or disclosure of PHI should be routed to the organization's controlled breach-assessment process. The record should preserve facts, evidence, scope, affected information, involved persons or entities, mitigation, decision rationale, reviewers, and applicable notification analysis.

Repository or automated QA must not decide whether an event is a legally reportable breach. That determination requires qualified human review based on the applicable facts and law.

Chapter 19 — Business associates and subcontractors

Business-associate governance should identify relationships involving PHI/ePHI, required agreements, permitted uses and disclosures, security expectations, incident and breach-notification duties, subcontractor dependencies, evidence requirements, and termination responsibilities.

A signed agreement is necessary evidence where applicable but is not proof of effective safeguards. Due diligence, ongoing monitoring, issue management, and access/data-return or destruction controls should be proportionate to risk.

Chapter 20 — Vendor and cloud-service oversight

Cloud, SaaS, managed service, hosting, analytics, support, and other vendors handling ePHI should be assessed for architecture, access, security controls, resilience, incident response, subcontractors, evidence, and contractual obligations appropriate to the service.

Vendor changes that materially alter hosting, subprocessors, security architecture, data location, access, or control ownership should trigger reassessment rather than being silently accepted.

Chapter 21 — Documentation and retention

HIPAA implementation evidence should be retained in a controlled manner consistent with applicable documentation requirements and organizational policy. Records should be dated, versioned where appropriate, attributable to an owner or reviewer, and protected against unauthorized alteration.

Useful evidence may include policies, procedures, risk analyses, approvals, training records, access reviews, technical configurations, logs, BAAs, incident records, breach assessments, remediation records, and evaluation results.

Chapter 22 — Evaluation and control testing

Periodic technical and non-technical evaluation should determine whether implemented safeguards and procedures remain aligned with the organization's environment, risks, and applicable HIPAA requirements.

Testing should use defined criteria, scope, samples where appropriate, expected results, actual results, limitations, findings, and reviewer conclusions. Evidence should distinguish control design from operating effectiveness.

Chapter 23 — Findings, corrective action, and validation

Findings should describe the criteria or expected condition, observed condition, evidence, risk implication, severity or priority, owner, corrective action, target date, and escalation path.

Closure requires sufficient validation that the corrective action addresses the underlying issue. Administrative completion without evidence should not be treated as remediation.

Chapter 24 — Exceptions and residual risk

Exceptions should document the unmet requirement or control expectation, business rationale, scope, compensating safeguards, residual risk, accountable owner, approver, expiration date, and monitoring requirement.

Expired or repeatedly extended exceptions should be reassessed. Where risk exceeds approved tolerance, escalation should be visible and decision authority explicit.

Chapter 25 — Change management and reassessment

Material changes to systems, applications, cloud services, vendors, data flows, access models, facilities, workforce processes, business relationships, or regulatory sources should trigger risk and control reassessment.

Change records should identify what changed, why, affected PHI/ePHI, impacted safeguards, testing performed, approvals, residual risk, and whether prior evidence remains valid. Material changes after review reopen affected approval gates.

Chapter 26 — Regulatory source watch

The organization should monitor authoritative HHS/OCR rulemaking and guidance relevant to its HIPAA program. Source-state records should identify current law separately from proposals, effective dates, superseded material, and the impact of official changes on controls, documentation, training, contracts, and technical implementation.

The HIPAA Security Rule NPRM remains readiness-only until a final rule changes the controlled baseline. Proposed requirements must be visibly labeled and must not be presented as current obligations.

Chapter 27 — Privacy and security governance reporting

Management reporting should summarize material risk, significant findings, overdue remediation, incidents, exceptions, business-associate issues, evaluation results, and regulatory changes in a form that supports accountable decisions.

Metrics should be traceable to evidence and should not hide unresolved high-risk conditions behind aggregate percentages. Governance bodies should record decisions, assigned actions, owners, and escalation where necessary.

Chapter 28 — Internal audit and independent review

Independent or second-line review should use defined scope, criteria, evidence, sampling, testing, and reporting methods appropriate to the engagement. Reviewers should disclose conflicts, limitations, and areas not tested.

A repository QA pass, certification held by a vendor, or existence of a policy must not be represented as an independent HIPAA compliance opinion. Formal assurance requires competent human judgment and sufficient appropriate evidence.

Chapter 29 — Evidence package for readiness or audit

A controlled readiness package should assemble the current scope statement, entity-role assumptions, PHI/ePHI inventory and data flows, risk analysis, risk-treatment records, safeguard evidence, workforce records, business-associate records, incident/breach-assessment records, evaluations, findings, remediation validation, exceptions, and approvals.

The package should reference the exact versions and dates reviewed so later changes can be distinguished from the assessed state.

Chapter 30 — Management review and approval

Management should review whether significant risks, findings, exceptions, incidents, remediation, vendor issues, and regulatory changes have been addressed or consciously accepted by authorized decision-makers.

Approval should record reviewer, date, decision, evidence considered, findings, required remediation, exceptions, and residual risk. Approval without sufficient context or authority should not satisfy the human-review gate.

Chapter 31 — Release and publication controls

Publication artifacts derived from this manual should preserve current-law/proposed-rule boundaries, legal and assurance disclaimers, source references, accessibility features, language metadata, reading order, links, tables, figures, alt text, and version/provenance information.

DOCX and PDF candidates should be regenerated after material source or content changes and subjected to page-level visual and accessibility QA before release.

Chapter 32 — Closure, maintenance, and continuous improvement

Manual 06 closes only when source verification, controlled English, legal/editorial/technical review, localization and semantic review, accessibility, publication QA, repository-security review, provenance, exact-head reconciliation, and Final Human Release Approval are complete for the same candidate.

After release, new HHS/OCR rules, material guidance, organizational changes, incidents, audit findings, or control failures should trigger impact analysis and, where material, a new controlled review cycle. Completion is a controlled baseline, not a claim that future compliance or security is guaranteed.